

Идентитет, аутентикација и RBAC

Идентитет, улоге, дозволе и серверска провера приступа

Идентитет и право приступа

Аутентикација потврђује идентитет. Ауторизација одређује да ли субјекат сме да изврши конкретну радњу.

ПОЈМОВИ

Четири различита појма

Идентитет, аутентикација, улога и дозвола имају различите одговорности у систему.

ОДЛУКА

Одлука је на серверу

Интерфејс може сакрити опцију, али не сме бити једина контрола приступа.

ДОКАЗ

Дозвољено и одбијено

Тест и ревизиони запис показују шта се догодило за исти тип радње у два контекста.

ПИТАЊЕ ЗА ПРОВЕРУ

Ко је субјекат, која дозвола је потребна и у ком опсегу она важи?

Раздвајање аутентикације и ауторизације

Спојене провере стварају претпоставку да аутентификован корисник има право на сваку доступну радњу.

НЕБЕЗБЕДНА ПРЕТПОСТАВКА

„Пријављен је, дакле сме“

Корисник може бити исправно аутентификован, а ипак не сме да одобри промену, чита туђи ресурс или мења конфигурацију.

ПОТПУНА ОДЛУКА

„Ко, шта, над чим и зашто?“

Сервер проверава активан идентитет, потребну дозволу, опсег и контекст конкретне радње.

ЗАКЉУЧАК

Раздвајање појмова смањује број скривених пречица и омогућава јасан ревизиони траг.

Основни појмови контроле приступа

Идентитет, аутентикација, улога и дозвола имају засебне функције у одлуци о приступу.

01

Идентитет

Ко је субјекат?
Трајна ознака и статус.

02

Аутентикација

Да ли је тврдња о идентитету
уверљива?

03

Улога

Коју пословну одговорност
субјекат има?

04

Дозвола

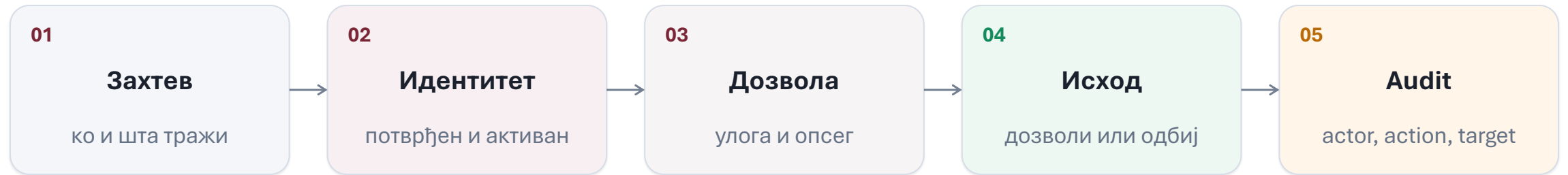
Коју конкретну радњу сме да
изврши?

МОДЕЛ ОДЛУКЕ

Ефективно право = улога + дозвола + опсег + актуелни статус идентитета

Поступак доношења одлуке о приступу

Сваки корак има дефинисан улаз, исход и разлог одбијања који се може проверити.



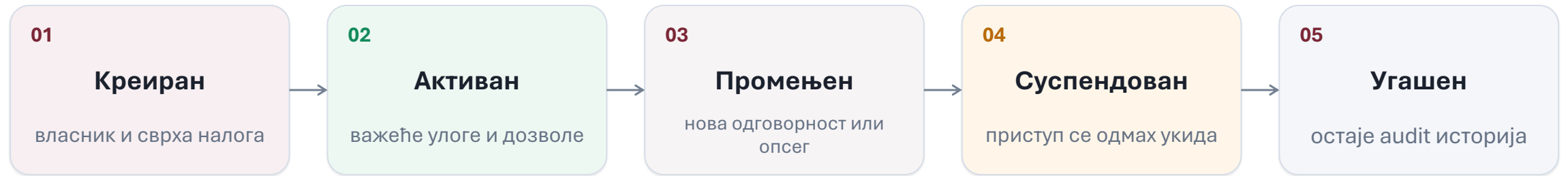
ЗАКЉУЧАК

Клијент може да води корисника, али сервер остаје једини ауторитет за одлуку.

Одбијање треба да буде контролисано: довољно јасно клијенту, без откривања заштићених детаља.

Животни циклус идентитета

Права приступа мењају се са статусом налога, организационом улогом и важењем додељених привилегија.



ДИЗАЈНЕРСКА ПОСЛЕДИЦА

Дизајнерска последица

Статус идентитета и промена улоге морају утицати на сваку нову одлуку, без ослањања на застарелу претпоставку клијента.

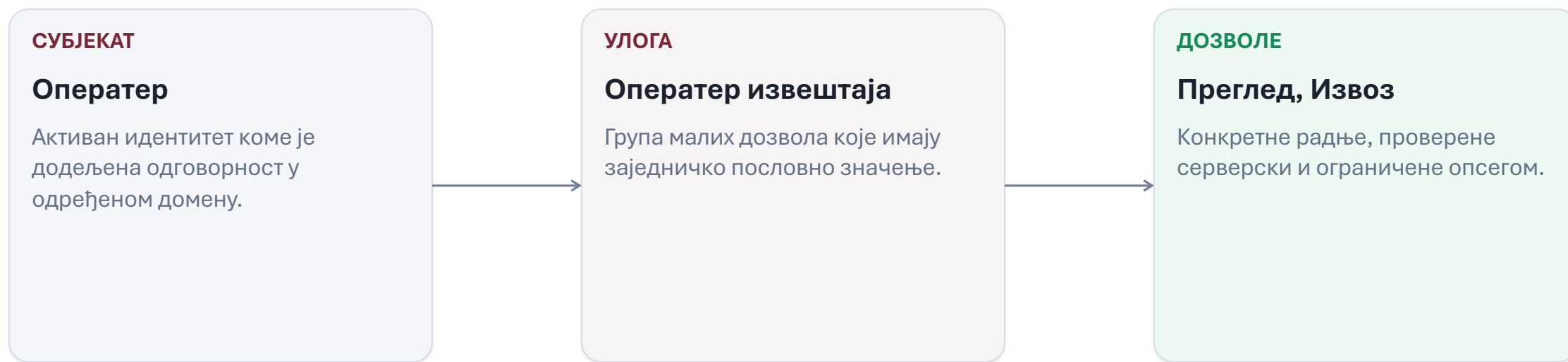
Аутентикација и ауторизација

Аутентикација потврђује идентитет, док ауторизација проверава право на конкретну радњу.

ПОЈАМ	ПИТАЊЕ	ТИПИЧНА ГРЕШКА
Идентитет	Ко је субјекат?	Особа и технички налог се третирају исто.
Аутентикација	Да ли је идентитет потврђен?	Успешна пријава се тумачи као широко овлашћење.
Ауторизација	Да ли је радња дозвољена?	Провера постоји само у корисничком интерфејсу.
Сесија	У ком привременом контексту право важи?	Token се третира као трајно право.

RBAC и пословна одговорност

Улога групише ограничен скуп дозвола које одговарају одређеној пословној одговорности.



ПРИНЦИП

Најмања привилегија: додели само право које је потребно, за опсег у коме је потребно и док потреба траје.

Серверска провера приступа

Сервер проверава дозволу и контекст захтева независно од стања корисничког интерфејса.

```
1 [Authorize]
2 [HttpPost("reports/{id}/approve")]
3 public IActionResult Approve(Guid id)
4 {
5     if (!access.Can(User, "report.approve", id))
6         return Forbid();
7
8     reports.Approve(id);
9     return NoContent();
10 }
```

ТУМАЧЕЊЕ

Пријава даје идентитет, не право на approve.
Дозвола је именована као конкретна радња.
Провера укључује и конкретан ресурс.
Одбијање се дешава пре пословне промене.

UI је помоћ, не контрола

Исти захтев мора бити безбедан и када се API позове директно.

Негативни тестови ауторизације

Тестови одбијања дефинишу границе дозволе и показују да сервер доследно спроводи правило.

```
1 [Test]
2 public void Viewer_cannot_approve_report()
3 {
4     var user = User.WithRole("Viewer");
5
6     var result = api.Approve(report.Id, user);
7
8     Assert.That(result.StatusCode, Is.EqualTo(403));
9     audit.AssertDenied(user.Id, "report.approve", report.Id);
10 }
```

Доказ има два слоја

КРИТЕРИЈУМ ПРОВЕРЕ

403, радња је одбијена

Стање ресурса остаје непромењено.

ТРАГ

Audit бележи покушај

Actor, action, target и исход могу се касније објаснити.

Привремено проширење одговорности

Широка администраторска улога додељује више права него што конкретан задатак захтева.

ПОТРЕБА

Одобравање једне врсте промене

Најпре се дефинише конкретна радња и њен ограничени опсег.

ОПСЕГ

Само један домен и ограничено време

Право важи у дефинисаном домену и престаје истеком пословне потребе.

РЕВИЗИЈА

Истек и ревизиони траг

Може се утврдити ко је доделио право, зашто и када је престало.

ЗАКЉУЧАК

Модел RBAC додељује најмању радњу оправдану пословном одговорношћу, у ограниченом опсегу и трајању.

Честе грешке у моделу приступа

Нејасно раздвајање улога, дозвола и контекста доводи до прекомерних привилегија.

01

Пријава = овлашћење

Систем не проверава посебно радњу и ресурс јер је корисник већ пријављен.

02

Преширока улога

Нова потреба се решава додавањем администратора уместо мале дозволе и опсега.

03

Сакривено дугме

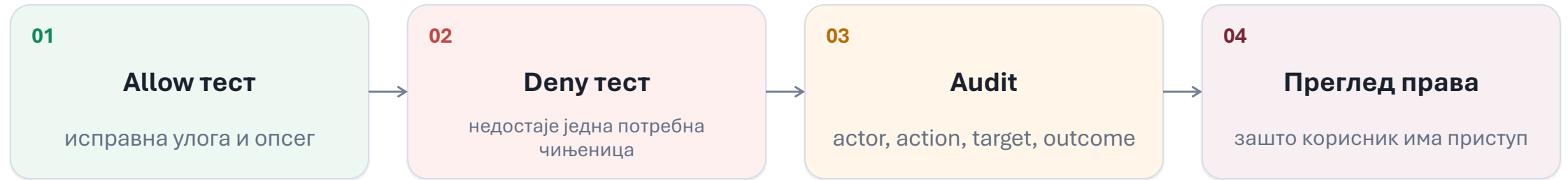
Клијент не приказује радњу, али сервер прихвата директан API позив.

КОНТРАМЕРА

Заједничка контрамера обухвата експлицитну серверску одлуку, тест одбијања и ревизиони исход.

Критеријуми исправног модела приступа

Модел обухвата позитивне и негативне сценарије, разлог одлуке и ревизиони запис.



ПРОВЕРЉИВ ЗАКЉУЧАК

Систем дозвољава оправдану радњу, одбија исту радњу без потребне дозволе и оставља траг који други члан тима може да понови и објасни.

Примена на пројекту

Пројектна целина треба да садржи једну серверску одлуку о приступу и проверљив доказ њеног исхода.

ИМПЛЕМЕНТАЦИЈА

Једна безбедносна одлука

Имплементација обухвата субјекат, радњу, дозволу и опсег. Серверска одлука користи актуелни статус идентитета.

ДОКАЗ

Сценарио дозволе и сценарио одбијања

Доказ обухвата тест или демонстрацију и ревизиони запис са актером, радњом, циљем и исходом.

ПРИПРЕМА ЗА P1

Припрема за P1 (после вежби 1–2): основна аутентикација и RBAC раде серверски. `object-level authorization` и негативан тест допуњују ланац.

Провера разумевања

Разумевање теме подразумева објашњење одлуке, контекста и доказа независно од конкретног технолошког оквира.

ПИТАЊЕ

За једну административну радњу објасните:

ко је субјекат, која дозвола је потребна, у ком опсегу важи, шта се бележи када је радња одбијена

Можете ли исту одлуку да формулишете као allow и deny тест?

Шта се мења ако је идентитет суспендован након пријаве?

Како доказујете да UI није једина контрола приступа?

Безбедно чување лозинки

Систем чува изведену вредност са соли и одговарајућим параметрима, без могућности враћања оригиналне лозинке.

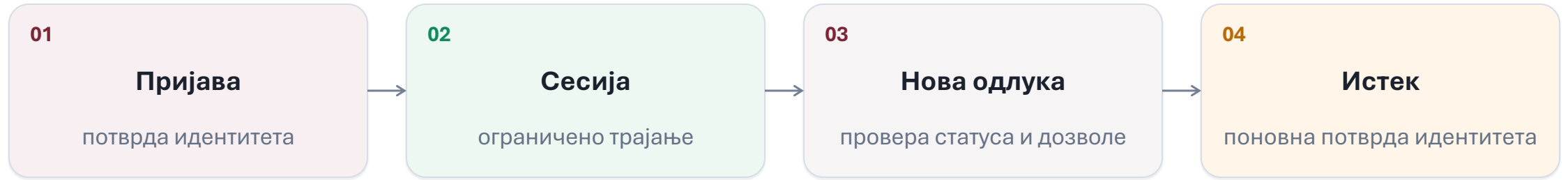
```
1 public PasswordRecord Create(string password)
2 {
3     var hash = hasher.HashPassword(user, password);
4     return new PasswordRecord(hash);
5 }
6
7 public bool Verify(string password, string hash)
8 {
9     return hasher.VerifyHashedPassword(user, hash, password)
10        == PasswordVerificationResult.Success;
11 }
```

ТУМАЧЕЊЕ

- 01 Стандардна библиотека управља хеширањем и salt вредношћу.
- 02 Иста порука покрива непостојећи налог и погрешну лозинку.
- 03 Промена лозинке укида стару тајну и оставља ревизиони траг.

Сесија као привремени безбедносни контекст

Токен преноси тврдње о субјекту у ограниченом периоду, док сервер проверава њихово важење.



БЕЗБЕДНОСНИ ИСХОД

Суспензија мора да има ефекат

Активан токен не сме сам по себи да надјача актуелни статус идентитета за нову осетљиву радњу.

Именованње улога и дозвола

Назив улоге описује пословну одговорност, а назив дозволе конкретну заштићену радњу.

ПРЕШИРОКО

Admin

Назив не објашњава које радње су оправдане, над којим ресурсима и колико дуго право важи.

ПРЕЦИЗНО

Оператер извештаја

Улога групише дозволе report.view и report.export у опсеру домена за који оператор одговара.

ПРАВИЛО МОДЕЛА

Промена пословне одговорности мења улогу. Нова техничка операција додаје малу дозволу у постојећи модел.

Садржај ревизионог записа

Запис омогућава реконструкцију покушаја без чувања лозинки, токена или непотребних личних података.

```
1 {  
2   "actor": "user-184",  
3   "action": "report.approve",  
4   "target": "report-902",  
5   "outcome": "denied",  
6   "reason": "missing_permission",  
7   "correlationId": "c-71f2"  
8 }
```

ДОВОЉНО ЗА ОБЈАШЊЕЊЕ

Субјекат, радња, циљ и исход

Correlation ID повезује одлуку са остатком тока захтева.

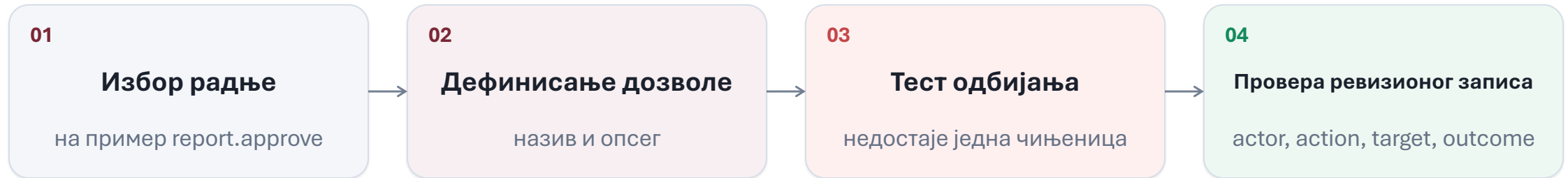
НЕ ПРИПАДА У ЛОГ

Лозинка, token и непотребни лични подаци

Ревизиони траг не садржи осетљиве вредности које би могле постати нови извор цурења.

Примена концепата

Анализа једне радње обухвата субјекат, дозволу, контекст, серверску одлуку и доказ исхода.



ОЧЕКИВАНИ РЕЗУЛТАТ

Очекивани резултат

Мала серверска промена, позитиван и негативан тест и кратко објашњење зашто дозвола има баш тај опсег.